

# Cascading Security Risks in Open Banking Ecosystem – An API-Centric approach to Modeling Third-Party Provider Trust Relationships

Prof. Funminiyi Olajide

Email – [spl6114@psu.edu](mailto:spl6114@psu.edu)

**IST 594 – M.S. Cybersecurity Analytics and Operations**

The Pennsylvania State University

May 2026

## Table of Contents

|                                                                             |           |
|-----------------------------------------------------------------------------|-----------|
| <b>Abstract .....</b>                                                       | <b>3</b>  |
| <b>List of Abbreviations .....</b>                                          | <b>4</b>  |
| <b>List of Tables .....</b>                                                 | <b>4</b>  |
| <b>List of Figures .....</b>                                                | <b>4</b>  |
| <b>Chapter 1 – Introduction .....</b>                                       | <b>5</b>  |
| 1.1 Background Information .....                                            | 5         |
| 1.2 Problem Statement .....                                                 | 6         |
| 1.3 Research Aims and Objectives.....                                       | 7         |
| 1.4 Research Questions .....                                                | 7         |
| 1.5 Risks and Ethical Considerations (PSEL).....                            | 7         |
| 1.6 Resources .....                                                         | 7         |
| 1.7 Significance of Research.....                                           | 8         |
| 1.8 Expected Outcomes .....                                                 | 9         |
| 1.9 Summary of Chapter 1 .....                                              | 9         |
| <b>Chapter 2 – Literature Review .....</b>                                  | <b>10</b> |
| 2.1 Introduction.....                                                       | 10        |
| 2.2 Theoretical Framework .....                                             | 10        |
| 2.3 Empirical Literature .....                                              | 10        |
| 2.4 Gaps in the Literature.....                                             | 13        |
| 2.5 Summary of Chapter 2 .....                                              | 14        |
| <b>Chapter 3 – Research Methodology .....</b>                               | <b>15</b> |
| 3.1 Research Philosophy.....                                                | 15        |
| 3.2 Research Design.....                                                    | 15        |
| 3.3 Research Strategy.....                                                  | 16        |
| 3.4 Data Collection Approach.....                                           | 17        |
| 3.5 Data Analysis Approach.....                                             | 18        |
| 3.6 Summary of Chapter 3 .....                                              | 19        |
| <b>Chapter 4 – Results and Data Analysis.....</b>                           | <b>21</b> |
| 4.1 Introduction.....                                                       | 21        |
| 4.2 Presentation Findings.....                                              | 21        |
| 4.3 Analysis of Findings .....                                              | 23        |
| 4.4 Summary of Chapter 4 .....                                              | 24        |
| <b>Chapter 5 – Discussion, Evaluation, Limitation and Future Work .....</b> | <b>25</b> |
| 5.1 Research Discussion .....                                               | 25        |
| 5.2 Evaluation .....                                                        | 25        |
| 5.3 Limitation.....                                                         | 25        |
| 5.4 Future Work .....                                                       | 26        |
| 5.5 Summary of Chapter 5 .....                                              | 26        |
| <b>Chapter 6 – Conclusion and Recommendations.....</b>                      | <b>27</b> |
| 6.1 Conclusion .....                                                        | 27        |
| 6.2 Recommendations.....                                                    | 28        |
| 6.3 Summary of Chapter 6 .....                                              | 29        |
| <b>References.....</b>                                                      | <b>30</b> |
| <b>Appendices .....</b>                                                     | <b>32</b> |

## Abstract

While APIs enable seamless integration between banks and third-party providers (TPPs) in the FinTech industry, they also introduce systemic risks that can propagate across the interconnected Open Banking infrastructure. This primarily arises from the trusted relationships banks have with the TPPs. Current security models are focused on API endpoint protection, compliance requirements, and vendor risk assessments. While they provide appropriate security standards to protect the perimeter of their infrastructure, their outward focus fails to model how a single compromised TPP can propagate cyber risks across multiple institutions within the interconnected system, ultimately leading to cascading failures. By analyzing a containerized and deployable testbed created using open-source tools to exploit API vulnerabilities, this research exposed system-level interactions capable of inducing cascading effects in the case of a third-party provider breach. It successfully demonstrated that credential theft via a breached TPP, in the absence of token signature validation, audience binding, or rate limiting, can expose customer information without generating an audit entry. The framework discussed in this paper reduces the attack surface by introducing granulated security mechanisms that can be implemented to prevent the cascading effect.

## List of Abbreviations

| Abbreviation | Meaning                                                                                             |
|--------------|-----------------------------------------------------------------------------------------------------|
| API          | Application Programming Interface                                                                   |
| TPP          | Third Party Provider                                                                                |
| PII          | Personally Identifiable Information                                                                 |
| OAuth        | Open-Standard Authorization                                                                         |
| OIDC         | Open ID Connect                                                                                     |
| OWASP        | Open Web Application Security Project                                                               |
| BOLA         | Broken Object Level Authorization                                                                   |
| PSD2         | Payment Services Directive 2                                                                        |
| SCA          | Strong Customer Authentication                                                                      |
| OBIE         | Open Banking Implementation Entity                                                                  |
| GDPR         | General Data Protection Regulation                                                                  |
| STRIDE       | Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege |
| PASTA        | Process for Attack Simulation and Threat Analysis                                                   |
| JWT          | JSON Web Token                                                                                      |

## List of Tables

| Table Number | Title                                               |
|--------------|-----------------------------------------------------|
| Table 1      | Scenario Selection and RQ Mapping                   |
| Table 2      | Analysis Method                                     |
| Table 3      | Comparative summary of findings from each iteration |
| Table 4      | STRIDE Threat Map                                   |

## List of Figures

| Figure Number | Title                         |
|---------------|-------------------------------|
| Figure 1      | Open Banking Ecosystem        |
| Figure 2      | Token Flow                    |
| Figure 3      | Attack Chain from Iteration 1 |

# Chapter 1 – Introduction

## 1.1 Background Information

Open Banking has significantly contributed towards the growth and modernization of the financial sector by introducing customer-delegated data sharing with Third-Party Providers (TPPs) via Application Programming Interfaces (APIs). While this API-driven business model encourages innovation and improves accessibility of banking services, it also introduces “cascading security risks” where a single TPP compromise can propagate across multiple interconnected banks.

Within the Open Banking environment, TPPs operate under a delegated trust model, utilizing customer authorization to access their banking information via APIs provided by their respective financial institutions. A single TPP partners with multiple banks simultaneously to offer the same services to a larger customer base. As a result, when a TPP is compromised, threat actors may leverage these connections to conduct unauthorized operations, such as initiating transactions, extracting sensitive customer data, as well as manipulating API requests across several connected banks. There were multiple breaches in 2024 that originated from third-party integrations, including the ransomware attack on Evolve Bank & Trust, where personally identifiable information (PII) of thousands of users was compromised, including those of the bank’s trusted partners like Affirm and Wise (Evolve Bank & Trust Data Breach. What Happened?, 2024). Such incidents abuse trusted relationships between banks and third-party providers.

The consequences of these incidents are significant. They may result in large-scale financial loss, regulatory penalties, operational disruptions, and reputational damages. Because they normally originate from trusted entities within the ecosystem, traditional threat detection and fraud prevention techniques struggle to prevent them in real-time.

Current cybersecurity practices in financial institutions largely focus on protecting internal systems and enforcing compliance-driven third-party risk assessments. While this approach ensures that reliable security baselines are established, they provide security from a threat model that conforms to expected API usage and lacks a cross-institutional perspective on risk propagation. Consequently, possible attack paths via compromised TPPs may not be discovered until significant damage has occurred (Behbehani et al., 2022)

Given the widespread adoption of Open Banking frameworks, there is limited research that systematically examines how TPP breaches can disseminate across multiple banks. Particularly, there exists a lack of API-centric threat modeling frameworks that can effectively analyze how fintech API functionalities can be abused and how such abuse propagates across interconnected institutions. Current studies also fail to offer systematic insights on how banks can detect and mitigate these risks in real-time. This gap presents a technical challenge for financial institutions and an opportunity for applied cybersecurity research.

To address these gaps, this research proposes an API-centric threat modeling approach to visualize cascading cybersecurity risks within the Open Banking ecosystem. The study tries to systematically identify API vulnerabilities specific to Open Banking and analyze potential attack paths that can traverse within this interconnected financial system.

## 1.2 Problem Statement

Through standardized and regulated systems like Open Banking APIs, financial institutions can delegate controlled access to consumers' sensitive data and payment capabilities to fintech platforms. While this architecture simplifies banking for consumers, it introduces complex relationships that needs to be carefully modeled from the security perspective. Current security approaches primarily focus on protecting API endpoints through authentication, authorization and vulnerability scanning. However, in practice, Open Banking ecosystems are highly interconnected and a breach of one trusted TPP can cascade risk across multiple financial institutions.

This research focuses on cascading cyber risk arising from delegated API access in Open Banking ecosystem where a compromise of a single TPP can result in a drastic impact. Unlike traditional supply chain attacks which focuses on software dependencies, this research actively looks for risks emerging from legitimate API usage patterns such as long-lived access tokens, weak consent revocation mechanism or obscure third-party dependencies.

### 1.3 Research Aims and Objectives

**Aim** – The goal of this research is to analyze and model how delegated API access in Open Banking systems can create cascading effect when a third-party provider is compromised.

**Objectives** –

- Designing an architectural baseline (testbed) using open-source tools that best represents a connection between a bank and a third-party provider in an Open Banking ecosystem.
- Identifying threats and vulnerabilities via threat modeling process and constructing attack path narratives involving three distinct breach scenarios.

### 1.4 Research Questions

**RQ 1** – What aspects of Open Banking API architecture enable unauthorized lateral movement when third-party providers are compromised and how do current perimeter-based API security controls (e.g., gateway monitoring, authentication protocols, anomaly detection) mitigate threats originating from such failures?

**RQ 2** – How can attack-path modeling techniques be utilized to identify cascading cybersecurity risk propagation across a trusted and interconnected Open Banking system?

**RQ 3** – How can an API-centric threat modeling framework be designed to embed resilience in Open Banking architecture and validate systemic fragility against cascading risks originating from TPP breaches?

### 1.5 Risks and Ethical Considerations (PSEL)

This study focuses solely on evaluating technical architecture and its security; hence, no human subjects are involved. As a result, IRB Compliance and Informed Consent are not applicable to this study. However, to maintain appropriate ethical standards, this research neither utilizes real-world private data nor does it explicitly specify any financial institution for developing attack scenarios. Additionally, the Kaggle dataset used in this study does not relate to any real-world financial institution.

### 1.6 Resources

This research study uses a controlled experimental environment to create a model Open Banking API architecture and simulates attack scenarios in a virtual machine to evaluate cascading risk propagation.

## **A. API Simulation and Development**

The following tools were used to simulate a simplified Open Banking architecture, including TPPs and banking API. A sample Kaggle dataset was used to populate database with schema normally found in banking database. Attack simulation was conducted in a virtual environment based on Kali Linux.

### **Technical Stack –**

- Orchestration/Microservices - Docker
- Python Fast API
- Database - PostgreSQL
- API Gateway - Kong
- Identity Provider (OAuth 2.0, OIDC) – Keycloak
- Attack Simulation – Postman, Burp, OWASP ZAP, custom Python scripts
- GitHub – Code Repository
- Data Flow Diagrams (DFDs) – Draw.io
- Framework – OWASP API Top10
- Virtual Machine – Kali Linux on Virtual Box
- Logging and Monitoring – Elastic, Logstash, and Kibana (ELK)

## **B. Threat Modeling and Analysis**

STRIDE framework was used to perform threat modeling exercise. Resulting data flow diagrams and attack paths were generated using Lucid Chart and Draw.io.

### **1.7 Significance of Research**

The significance of this research lies in addressing the lack of frameworks that allow financial institution to comprehend trust propagation and blast radius within API driven systems. While the existing regulatory standards like Open Banking Implementation Entity (OBIE) and SCA provide appropriate guidelines that

acknowledge third-party risks, they lack technical insight on modeling API-level trust. This study aims to bridge that gap by formally analyzing API permissions and third-party integrations to identify cascading security risks.

## 1.8 Expected Outcomes

This research is relevant to product security and fintech risk engineering where understanding and modeling risks is a necessary component. This work seeks to produce insights useful for building security tools, defining procedures and improving policies that can support proactive risk mitigation in financial API ecosystems.

## 1.9 Summary of Chapter 1

Chapter 1 introduces security challenges inherent in the Open Banking framework, specifically highlighting the cascading risk created by the interconnected nature influenced by API integration. While the delegated trust model allows Third-Party Providers (TPPs) to innovate, it simultaneously creates a single point of failure such that a single TPP compromise can propagate across multiple connected financial institutions. Based on this central idea, this study aims to develop an API-centric threat modeling framework to visualize and mitigate attack paths originating from a breached TPP. Using a controlled environment, this research simulates real-world scenarios to provide actionable insights.

## Chapter 2 – Literature Review

### 2.1 Introduction

The literature review presented in this section discusses technical and interconnected nature of Open Banking ecosystem, specifically focusing on API integration and risk management. The following section provides a brief overview of Application Programming Interfaces (APIs), the frameworks governing trust and compliance, and analysis of current empirical studies that suggests systemic risks in financial models. By combining these aspects, this chapter highlights the need for integrated risk assessment models in a highly interconnected environment.

### 2.2 Theoretical Framework

The Open Banking model is theoretically grounded in concept of delegated access and compliance-security paradox.

**Delegated Access via OAuth 2.0** – The primary framework implemented for managing customer consent is OAuth 2.0. It is responsible for enforcing the principle of delegated access, allowing Third-Party Provider (TPPs) to access customer data with their permission without exposing their primary credentials. However, as noted by Munugoti (2025), while this mechanism facilitates smooth data handling, it creates “points of failure” in trusted relationships established within the current implementation.

**Compliance-Security Paradox** – This theory is rooted in regulatory mandates and technical gaps such that legal compliance often results in poor implementation of system level interactions. While frameworks like Open Banking foster innovation and opens new markets, technical infrastructure often lacks the maturity to mitigate security vulnerabilities. This creates a scenario where regulatory compliance may inadvertently introduce novel attack surfaces.

### 2.3 Empirical Literature

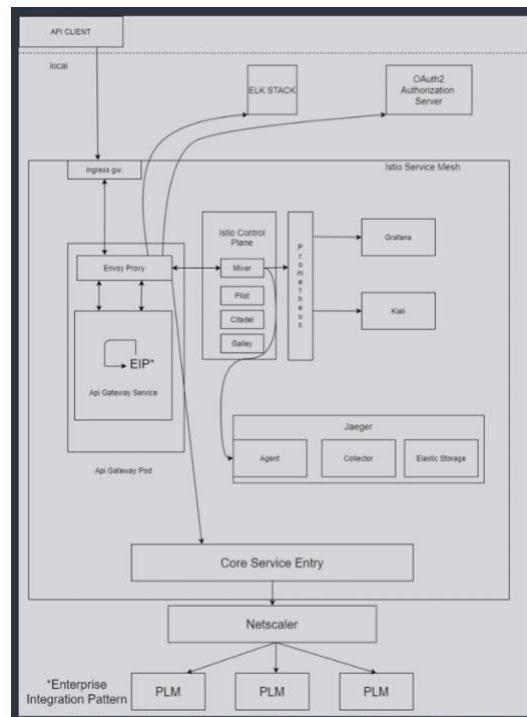
#### A. Open Banking Architecture and API Ecosystem

Application Programming Interfaces (APIs) serve as the primary technological mechanism that allows the interactions between the TPPs and the banks. These interactions are enabled at the behest of customers availing

services provided by the TPPs. Customers can initiate payments, access account information, allow TPPs to perform transaction analytics, etc., using the Open Banking model.

This ecosystem facilitates a single TPP to use banks' APIs and build services on top of traditional banking infrastructure. Despite this innovative approach, the Open Banking ecosystem introduces architectural complexity and security challenges of its own (Ünsal et al., 2020).

APIs allow connecting two different systems through an agreed-upon protocol that is vendor-neutral as well as language-neutral. They provide a set of operations defined by specific inputs and outputs. In Open Banking architecture, banks are forced to reveal the data belonging to their customers to TPP via APIs.



**Figure 1 Open Banking API Design**

Note. From "Building a Fintech Ecosystem: Design and Development of a Fintech API Gateway," by E. Ünsal, B. Öztekin, M. Çavuş, and S. Özdemir, 2020, 2020 International Symposium on Networks, Computers and Communications (ISNCC), p. 3 (<https://doi.org/10.1109/ISNCC49221.2020.9297273>). Copyright 2020 by IEEE.

Since APIs form a basis in the Open Banking model, significant efforts are required in building a resilient and reliable architecture for communication between trusted parties. A general fintech API architecture includes an API client and an API gateway. The API client sits outside the local environment. The gateway makes a relevant transformation on the request received from the client and is then sent back in a specified format to be used by the TPPs. The banks and TPPs are free to deploy relevant security monitoring in their architecture.

Another important aspect to note about Open Banking is authorization. API gateways use OAuth 2.0 for authorization and consent handling. OAuth 2.0 is a framework that enforces the concept of “delegated-access” for customer data handling in the Open Banking architecture (Shashi Kumar Munugoti, 2025). While it effectively facilitates delegated access, it creates a “point of failure” in trust relationships that Munugoti (2025) acknowledges but do not solve.

Despite the existence of standardized API architecture and frameworks, Open Banking APIs can expose critical financial services to external threat actors, increasing the attack surface for the banks. Multiple studies highlight the high risk associated with API misconfigurations, authentication flaws, and improper deployment of access control policies. As financial services become technologically reliant and API-driven, securing these interfaces becomes a main concern for regulators and banks (Wilson & Tam, 2026).

## **B. API Security Risks in Financial Systems**

API security emerges as the critical component in the Open Banking implementation strategies. Research on API vulnerabilities identify common weaknesses such as broken object level authorization (BOLA), excessive data exposure, and improper authentication mechanisms (OWASP, 2023). In the financial system, such vulnerabilities can allow unauthorized access to sensitive customer information or can enable attackers to manipulate API requests.

Financial institutions participate in the Open Banking system at the behest of the government directives, following strict implementation guidelines. This creates a ‘compliance-security paradox’ wherein frameworks like PSD2 legally compel banks to expose APIs while the current technical infrastructure lacks the maturity to completely mitigate the resulting security risks. Frameworks like PSD2 or OBIE also require the TPPs to register with government bodies to operate. While this helps prevent fraud and ensure data security for customers, any mishaps involving these services have to be largely taken care of by the banks. Thus, an Open Banking ecosystem where trusted TPPs need to maintain persistent API access must approach security with respect to these trusted entities (Ünsal et al., 2020).

## **C. Third-Party Provider Trust Relationships and Risk Management in Open Banking Ecosystem**

Financial institutions rely heavily on third-party vendors for software development, data processing, and providing digital services. To manage risks associated with them, banks implement vendor risk management programs that assess the security posture of third-party providers. These programs may include compliance audits, contractual agreements, security certifications etc. While these efforts ensure baseline security for banking infrastructure, third-party providers with maintained access to the banks via APIs altogether introduce a risk environment that may not be sufficiently covered under the third-party vendor risk assessments (Ojehomon et al., 2026).

#### **D. Cascading and Systemic Risks in Financial Systems**

Open Banking drives a drastic change in the financial sector by helping banks transition from closed, institution-centric systems to highly interconnected, API-driven ecosystems. Increased reliance on APIs and TPP access heightens exposure to cybersecurity threats, privacy violations, and operational disruption, with a huge impact on reputation with an overhead of regulatory penalty. These threats affect multiple stakeholders involved in the process. Customers face elevated risks of fraud, identity theft, and data misuse, while banks, on the other hand, are burdened with exposure from third-party failures. This can result in the ecosystem as a whole being affected with instability and may experience heightened cross-platform contagion (Zetzsche et al., 2019). Regulatory guidelines and legal policies such as PSD2 and GDPR complicate liability allocation (Ojehomon et al., 2026). While these problems are highlighted by most studies, they are focused on individual aspect of Open Banking risk which are analyzed in isolation. Subsequently, limited attention has been paid to the trusted interactions that take place within this interconnected ecosystem. There exists a clear research gap that could analyze integrated and dynamic-risk assessment approaches to captures the multidimensional nature of Open Banking threats (Ojehomon et al., 2026).

### **2.4 Gaps in the Literature**

Despite the growing attention to API security and third-party risk management, several research gaps persist. Existing literature examines and acknowledges Open Banking cybersecurity risks, API-level flaws, third-party dependencies, as well as regulatory mechanisms to safeguard customers and prevent fraud. However, it lacks a

comprehensive assessment of technical breaches at the TPP level, which can translate into systemic and non-linear cascading risks in a financial network. Existing risk management in Open Banking tends to be heavily analyzed in an isolated manner, focused on individual risks instead of capturing the multifaceted nature of threats inherent in this interconnected ecosystem (Ojehomon et al., 2026). Moreover, current cybersecurity frameworks do not provide formal models for analyzing cascading cyber risks across API-enabled financial ecosystems.

This study aims to address these gaps by considering the ecosystem-level approach put forth by Ojehomon et al. (2026), treating Open Banking as a network of interconnected nodes where TPPs act as links to contagion. This work can help develop effective cybersecurity strategies that banks can use to protect themselves from potential risks associated with trusted TPPs.

## 2.5 Summary of Chapter 2

In summary, while transitioning to API-driven business models within the Fin-Tech sector offers engagement in newer markets, it introduces complex security challenges that take time to evolve and mitigate. The literature review discussed in this section identifies significant research gaps, which suggest limited research on integrated, dynamic risk assessment approaches that capture the interconnected nature of the Open Banking ecosystem. This research aims to fill that gap by analyzing system-level interactions to identify and prevent systemic risks.

## Chapter 3 – Research Methodology

### 3.1 Research Philosophy

This research on cascading security risks in the Open Banking ecosystem adopts an interpretivist paradigm to investigate how an API-centric threat modeling framework can be designed to embed resilience in Open Banking architecture and validate systemic fragility against risks originating from third-party provider compromises. Rather than measuring static data, this paradigm enables interpretation of complex technical architecture and identifies attack paths that can emerge when trusted relationships are exploited within the Open Banking framework.

It follows an exploratory design logic to analyze the technical implementation of Open Banking APIs and evaluate potential attack vectors that can be employed by malicious entities. Because the risks propagate from authorized but compromised TPPs, an exploratory approach allows to uncover vulnerabilities that traditional security frameworks may overlook. By utilizing existing threat modeling frameworks, the research will systematically examine the Open Banking architecture to map potential attack paths arising from TPP exposure. The goal of this study is to develop a framework that enables banks and third-party providers to detect and secure attack paths, resulting in a proactive mechanism that defends against lateral movement and minimizes the systemic impact of a trusted TPP breach.

### 3.2 Research Design

A qualitative design is selected because the research questions seek to capture system-level interactions and identify risk propagation within the interconnected Open Banking system. While a quantitative method could be valuable for validating the attack vectors, the study would become limited in scope due to the constrained environment setup. Furthermore, it would lack depth in its outcomes as proprietary banking data, including real-world technical infrastructure and transactional logs, are highly confidential and hence, a purely evidence-based study would be unfeasible for the research.

In place of numerical datasets, the research will utilize a narrative data type. This will include detailed attack-path constructions and logical step-by-step application of threat modeling frameworks like STRIDE, PASTA, and DREAD, widely used in the industry (Modesti et al., 2025). By documenting the narrative of an exploit, the

study will be able to effectively capture system-level interactions that may be overlooked by a quantitative study.

This methodology is supported by current literature, which emphasizes the lack of systemic risk modeling within the interconnected nature of the Open Banking model. While Behbehani (2022) utilized a probabilistic approach to construct Bayesian attack graphs, their primary approach utilized the STRIDE threat modeling framework to generate attack predictions, which was qualitative in nature. Hence, focusing on the basic evaluation of how a breach propagates, the qualitative method provides a comparatively detailed understanding of interconnected risks.

### 3.3 Research Strategy

The target population for this research includes Open Banking API providers, i.e., financial institutions, and the Third-Party Providers (TPP). Hence, it follows a purposive, criterion-based sampling strategy where three distinct breach scenarios are carefully constructed, inspired by real-world incidents closely related to the FinTech industry. These scenarios serve as the primary units for attack-simulation on a replicated Open Banking environment, focused on exploiting vulnerabilities by adhering to OWASP API Top 10 framework. The construction of this testbed architecture is based on the available industry-standard literature, which utilizes open-source tools to implement core components, including API integrations and OAuth2.0/OIDC protocols. To allow for the simulation of a realistic data flow, this environment is also populated with a Bank Transaction Dataset (Khorasani, 2024).

Table 1 Scenario Selection and RQ Mapping

| Type                       | RQ      | Entry Point              | Target                                                       |
|----------------------------|---------|--------------------------|--------------------------------------------------------------|
| Credential Theft           | RQ1     | Plaintext OAuth Secret   | APIs Sharing Trust Boundaries                                |
| Lateral Movement & Cascade | RQ2     | Compromised Access Token | Accounts, Payments, Transfers<br>API, Full Customer Database |
| Framework Validation       | RQ2/RQ3 | Scenario 1 + 2           | Resilience Test                                              |

The research also follows a well-documented, iterative process applying threat modeling frameworks to the designed architecture. Its primary purpose is to identify cascading risk propagation, especially mapping how one flaw enables another flaw in the said interconnected ecosystem. The outcome of this methodology is used to

develop a robust mitigation strategy, including design policies to be adopted in the implementation of an Open Banking architecture.

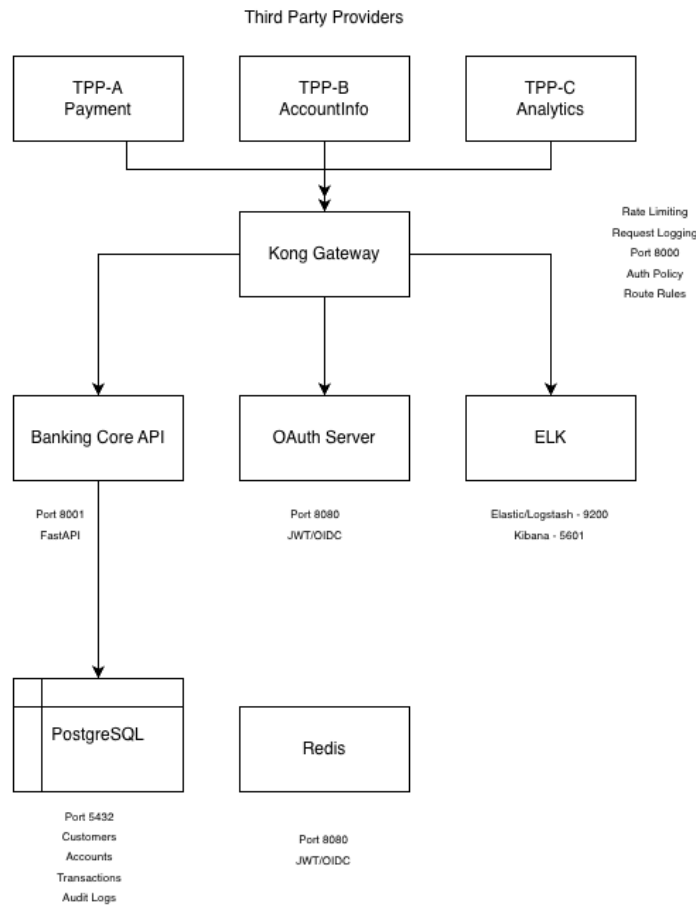
### 3.4 Data Collection Approach

The data collection approach in this study performs a technical investigation to uncover system limitations. Eight instruments were categorized and utilized for analysis – Entry Point Analysis, Vulnerability Mapping, Authentication Resilience, Propagation Logic, Control Evaluation, Detection Patterns, Visibility Gaps, Mitigation Strategy.

#### **A. Simulation Architecture**

A microservices-based architecture to simulate Open Banking was constructed using five services – OAuth 2.0 authentication server, an accounts API, a Payments API, a Transfers API and a TPP simulator. These services were implemented using Fast API framework and were containerized using Docker Compose. A PostgreSQL database was used to serve as a persistent storage. Redis was included to support token caching.

The simulation was made possible by populating data from the Bank Transfer Dataset for Fraud Detection (Kaggle, 2024), containing approximately 2,512 samples of transaction data that consisted various transaction attributes such as customer demographics, and usage patterns. This dataset was chosen as it reflects realistic attributes often found in banking operations.



**Figure 2 Open Banking Ecosystem**

## B. Threat Modeling Framework

Each scenario was analyzed using the iterative process derived from STRIDE threat modeling framework. The framework includes following categories – Spoofing (TPP Credential Impersonation), Tampering (Token Forgery), Repudiation (Absent Audit Logging), Information Disclosure (Mass Data Exfiltration), Denial of Service (not a focus in this study, but helpful for impact analysis), Elevation of Privilege (Scope Violations Resulting in Fund Transfers).

### 3.5 Data Analysis Approach

Rather than using surveys or interviews, this study performs a technical investigation to uncover system limitations. It maps each of the data collection instrument with a specific analysis approach. Thus, this investigation focused on these key areas is summarized in Table 2 as follows -

**Table 2 Analysis Method**

| Data Collection Instrument | Purpose | Analysis Method |
|----------------------------|---------|-----------------|
|----------------------------|---------|-----------------|

|                           |                                                                                                                                                                                                                             |                                                                                                                                                                  |
|---------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Entry Point Analysis      | Identify entry points that allow access to multiple banking APIs during a TPP breach.                                                                                                                                       | (1) Identify all ways an attacker can compromise TPP, (2) Document how the TPP connects to APIs/endpoints, (3) Map which data the TPP can access.                |
| Vulnerability Mapping     | Detect high-risk components in the architecture.                                                                                                                                                                            | (1) For each entry point, identify the architectural flaw, (2) Map each flaw to OWASP (or CWE) standard, (3) Explain the vulnerability in Open Banking context.  |
| Authentication Resilience | Analyze current OIDC/OAuth implementation to validate the integrity of TPP's security against established regulatory guidelines such as SCA (Strong Customer Authentication) and PSD2 (Revised Payment Services Directive). | (1) Test authentication mechanisms against regulatory requirements, (2) Analyze OAuth and PSD2 alignment, (3) Analyze Token validation and GDPR data protection. |
| Propagation Logic         | Modeling how "trusted but unauthorized" actions can move through the system.                                                                                                                                                | (1) Create attack paths showing how one compromise spreads, (2) Show sequence of actions required, (3) Identify points where breach could be stopped.            |
| Control Evaluation        | Assessing the effectiveness of existing perimeter-based security controls.                                                                                                                                                  | (1) For each attack step, identify what security control would catch it, (2) List security controls tested, (3) Document what failed and analyze what succeeded. |
| Detection Patterns        | Recognizing patterns to alert a TPP breach risk propagation.                                                                                                                                                                | (1) Design detection rules that could catch the attack, (2) Explain why they were missing and how it would relate to real-world implementation.                  |
| Visibility Gaps           | Identifying technical and regulatory factors contributing to delayed incident response during a TPP breach.                                                                                                                 | (1) Show what log data and dependencies are needed for visibility, (2) Identify regulatory impact, PSD2 liability, GDPR breach.                                  |
| Mitigation Strategy       | Evaluating how the proposed framework can be integrated within the currently followed industry-best practices.                                                                                                              | (1) For every vulnerability exploited, propose specific mitigation, (2) Map mitigation to RQ3.                                                                   |

### 3.6 Summary of Chapter 3

This research adopts an interpretivist paradigm and an exploratory qualitative design to investigate systemic interactions in the Open Banking architecture to identify cascading third-party risks. By prioritizing eight data collection instruments paired with iterative threat modeling and attack simulation, this study follows a rigorous

technical investigation. The research methodology provides careful consideration to its reproducibility and validity.

## Chapter 4 – Results and Data Analysis

### 4.1 Introduction

This chapter presents and analyses the data collected across three iterations of threat modeling study performed on a test-bed architecture. It discusses each iteration in detail and provides an overview of the findings. The analysis approach utilized in this section is comparative. Results of from these iterations are also summarized in structured tables. The chapter concludes by identifying the key insights that stem from applying the research methodology discussed in the previous chapter.

### 4.2 Presentation Findings

#### **Iteration 1 – Unauthorized Access using Credential Theft**

When all security controls are disabled, adversary in possession of a TPP client identifier and secret can obtain a valid OAuth access token. This token is issued without any warning or a multi-step verification process that notifies an authorization code exchange has occurred. Moreover, tokens with arbitrary payloads are accepted with same token being used for all API surfaces.

This token helps an adversary to retrieve the complete account list. In the simulation, this resulted in all the customer records being exposed. Since, this phase of simulation had no security, absence of rate limiting measure resulted in extraction of entire database in a period proportional to network throughput. Additionally, no audit log entries are written which heavily limits the ability to even identify that an attack occurred. No indicators of compromise could be assessed, or alerts could be generated. This scenario can lead to devastating consequences in a real-world scenario.

The STRIDE analysis identifies primary threat categories as -

- Spoofing - Attacker impersonates a legitimate TPP
- Information Disclosure - Customer Account data is accessed by unauthorized user
- Elevation of Privilege - The read-scoped token permits write operation due to the absence of scope enforcement

OWASP API vulnerabilities exploited in this iteration includes Broken Authentication (API2:2023), Unrestricted Resource Consumption (API4:2023), and Broken Function Level Authorization (API5:2023).

## **Iteration 2 – Lateral Movement and Cascade Effect**

In this iteration, token signature verification was enabled, but audience binding and scope enforcement were left as it is, leaving them exposed. The assumed adversary now needs to present a token signed by a legitimate OAuth server. However, since the audience claim is not checked, a token issued to the TPP for the payments API can be forwarded to the accounts API and also be presented as if it originated from another TPP. This demonstrates the cascade mechanism, i.e., a single point of compromise can be leveraged to traverse across the ecosystem because trust is implicitly extended to any party holding a valid token. It did not check who this token was issued to or what resource it was intended for.

It is important to note here that audit logging was enabled in this iteration. This behavior could be identified in logs, but since no alerts were set up, it couldn't be identified. Lateral movement occurs before an alert is triggered.

## **Iteration 3 – Framework Validation**

All basic security mechanisms are enabled in this iteration. A token signed with the wrong secret is rejected, which confirms that the signature validation is enforced independently of the OAuth server. A token carrying the wrong audience claim is rejected as well. This prevents lateral movement across APIs. An attempt to perform a write operation when the access is limited to a read operation is also prevented after scope enforcement is applied. Privilege escalation is now blocked.

The rate-limiting rule also gets triggered after multiple consecutive requests are detected from the same TPP in a 60-second window. Everything is sent to audit logs, providing full visibility into the activity that occurred.

The net effect is the reduction of the attack surface and reduced impact from the full database exposure to alert generation within a minute as the rate limiting rule gets triggered instantly.

## 4.3 Analysis of Findings

### A. Architectural Implications

The findings confirm the central argument of the study that perimeter-based security mechanisms are insufficient when the trusted part that crossed the perimeter itself is compromised. Once a TPP token is stolen, the attacker is granted access inside the perimeter. The controls that matter in this stage are post-perimeter measures implemented to scope authorizations, restrict operations outside the scope and limits that put constraints on the attacker to cause further damage.

This has direct implication on how the Open Banking architectures should be designed. The current PSD2 framework mandates strong customer authentication (SCA) and secure communication protocols but does not prescribe the management of system-level interactions that occur once the access is granted to TPPs. The simulation results suggests that if these gaps exist in the TPP integration with banking APIs, it can create a large attack surface for adversaries to operate.

### B. Cascade Mechanism

The lateral movement identified in the second iteration revealed the systemic nature of risks in Open Banking frameworks. When trust is enforced in binary terms, meaning, if a token is valid or not, it can extend risks that allow threat actors to perform action which were not intended in the first place. Without scope enforcement, operations can result in data theft. The cascade, therefore, does not arrive from the failure of a single control mechanism but as a result of missing granular controls that fail to contain the threats. Each individual layer of defense can have gaps, and a cascade occurs when these gaps align together.

**Table 3 Comparative summary of findings from each iteration**

| Metric                    | Iteration 1 (No controls) | Iteration 2 (Partial) | Iteration 3 (Framework) |
|---------------------------|---------------------------|-----------------------|-------------------------|
| Token Signature Check     | None                      | Enforced              | Enforced                |
| Audience Binding          | None                      | None                  | Enforced                |
| Scope Enforcement         | None                      | None                  | Enforced                |
| Rate Limiting             | None                      | Enforced              | Enforced                |
| Audit Logging             | None                      | Enforced              | Enforced                |
| Forged Token Accepted     | Yes                       | No                    | No                      |
| Lateral Movement Possible | Yes                       | Yes                   | No                      |
| Scope Escalation Possible | Yes                       | Yes                   | No                      |
| Records Exposed           | All                       | Many                  | Rate Limiting           |

## 4.4 Summary of Chapter 4

This chapter presented the findings obtained from the simulation performed on the testbed architecture. It discussed results from each iteration and provided insights directly relevant to the research questions posed by the study. The key insights from this section are as follows -

- Credential theft in the absence of security controls such as token validation, audience binding and scope enforcement can produce complete and undetectable compromise.
- Lateral movement is a consequence of missing audience claims rather than the failure of OAuth itself.
- Audit Logging is necessary but not a sufficient condition for effective response. Its value lies in providing indicators of compromise and generating real-time alerts useful for immediate mitigation response.

## Chapter 5 – Discussion, Evaluation, Limitation and Future Work

### 5.1 Research Discussion

The findings of this study are consistent with the theoretical and empirical literature provided before. The vulnerability to credential theft demonstrated in iteration 1 are consistent with the results provided by Ünsal et al. (2020) in their analysis of OAuth 2.0. The simulation confirms that when the client secret is exposed, the cascading consequences are immediate and if no controls are present, it could have damaging consequences. Additionally, the successful exploitation of vulnerabilities mentioned in OWASP API Top Ten (2023) suggests that these prominent API vulnerabilities are inherent in Open Banking architecture. It also proves the interconnected nature of Open Banking systems suggested by Ojehomon et al. (2026). The findings from this study prove the security risks presented by delegated access theory mentioned in prior sections.

### 5.2 Evaluation

The simulation-based approach adopted in this study is technically rigorous. The use of containerized environment using Docker ensured that the experiment was reproducible. The iterative design comprising of variable and configuration changes in each scenario made sure they provide effective metrics for comparative analysis. Enabling security controls with each iteration instead of utilizing all of them at once helped identify its effectiveness individually. Additionally, the decision to use an available dataset that resembles banking database schema provided attributes that may be encountered in real-world scenarios. Instead of generating synthetic data, using real-world attributes improved the validity of the experimental set-up. This is because, attributes such as transaction ID and device information can help correlate pieces of information exactly the way adversaries do. This aspect was missed in the initial design but was later incorporated in later stages.

### 5.3 Limitation

While the study showed the importance of cascading effects in the Open Banking framework, several limitations restrict the generalizability of the results. The simulation uses a synthetic dataset that relates to banking transactions. This may differ significantly and depend on the way banks implement their database schema. The attacks scripts presented in this work are simplified and do not resemble sophisticated attacks such as supply-chain attacks, insider threats, or network-layer attacks. This complexity is not observed in this

simulation but may occur in real-world production environments. This renders the findings limited in scope; however, it presents an opportunity for future research direction where a model banking dataset can be created for accurate studies.

## 5.4 Future Work

Future work should examine framework performance under novel adversarial conditions not presented here. It should also utilize AI/ML aspects in discovering attack propagation paths as well as mitigation strategies to further strengthen banking security.

## 5.5 Summary of Chapter 5

This chapter provided insights into the findings of this research in accordance with the literature review and the theoretical framework discussed previously. It also critically examined the research methodology and listed its strengths and limitations. While the method employed in this study is reproducible and emphasizes the use of a dataset that relates closely to real-world banking schema, it also acknowledges the simplicity of attacks simulated on the testbed. Complex tactics used by adversaries could differ significantly from the ones used for this study, and the real-world banking schema may look very different from the one utilized here. This leaves an opportunity for future work to consider advanced tactics to simulate adversary behavior and employ advanced techniques using artificial intelligence and machine learning to identify relevant points of failure within the trusted ecosystem.

## Chapter 6 – Conclusion and Recommendations

### 6.1 Conclusion

The answers to the research questions posed by this study can be concluded as follows -

**RQ1 – What aspects of Open Banking API architecture enable unauthorized lateral movement when third-party providers are compromised and how do current perimeter-based API security controls (e.g., gateway monitoring, authentication protocols, anomaly detection) mitigate threats originating from such failures?**

The simulation demonstrated that four specific architectural aspects – missing token signature validation, audience claim enforcement, and scope per operation validation can create a direct path from credential theft to complete compromise of the banking database. Perimeter-focused controls like OAuth authorization flow and API gateway routing are insufficient as they operate at the boundary of the ecosystem and not within the ecosystem.

**RQ2 – How can attack-path modeling techniques be utilized to identify cascading cybersecurity risk propagation across a trusted and interconnected Open Banking system?**

The three-iteration process, structured around the STRIDE threat modeling framework and attack execution, provided a systematic method of identifying system-level interactions that can result in compromise from trusted relationships. The key insight is that lateral movement could form a chain such that credential theft enables token issuance, missing audience validation enables API traversal, and the missing scope enforcement per operation can finally escalate privileges. Attack path modeling starts at the token level instead of the architectural perimeter.

**RQ3 – How can an API-centric threat modeling framework be designed to embed resilience in Open Banking architecture and validate systemic fragility against cascading risks originating from TPP breaches?**

The three-iteration model in conjunction with classic threat modeling framework can help analyze API vulnerabilities at the system-level interaction. It provides paths an adversary can traverse in the absence of a specific security control. Instead of applying security controls all at once, enabling them with each iteration serves as an effective mechanism to identify points of failure and secure them with appropriate measures.

While Open Banking frameworks enable markets where new ideas and technology can operate together within the banking industry, they could be limited by the very nature of their implementation. This research set out to identify architectural flaws that enable adversaries to move within this interconnected network following a TPP compromise, to identify attack paths leading to cascading propagation, and to develop a framework that can validate systemic resilience. The three-iteration simulation design provided sufficient evidence to identify these vectors. The absence of token signature validation, audience binding, and scope enforcement creates a direct traversal path from credential theft to data exposure. Identifying such granular system-level interactions and enforcing appropriate security mechanisms can sufficiently contain adversarial impact resulting from violations of trust relationships in the interconnected network.

## 6.2 Recommendations

This study provides following recommendations for organizations, policy maker and academic contributors -

### **A. Practice: Actionable Steps for Organizations**

OAuth scopes should be clearly defined and enforced at the level of individual operations. A scope of read should not allow written access to another endpoint. Scope definitions should be handled by including it in the API specification and validating it in the request handling code.

Rate limiting is the most effective solution to prevent unauthorized operations from a trusted TPP. Organizations should design their API implementation by constructing a baseline for traffic volume they could receive and attach a limit to prevent a TPP from accessing resources without any limits.

### **B. Policy: Guidance for Policymakers**

Standards bodies that are responsible for introducing Open Banking frameworks such as PSD2, should consider updating technical guidelines to require TPP access tokens to carry audience claims binding them to specific API resources and resource servers should validate these claims independently.

Audit logging at the API level and mandate it as part of the compliance obligation. Adding it as a concrete requirement for policies like GDPR. For instance, GDPR articles specify incident reporting however, adding API-level logging as a mandatory technical requirement could act as a necessary supplement to incident reporting. This could enhance log retention for root-cause analysis and can be further utilized for making informed decision around strengthening security posture.

Current security implementations do not govern the relationships between a bank and a TPP stringently. The systemic risk arising from TPP breach through shared API structure should be explicitly addressed in policies mandates for Open Banking implementation.

### **C. Theory: Contributions to Academic Knowledge**

The simulation design with three iterations, structured around STRIDE threat modeling framework provides a reusable template that can be further improvised to design a more robust threat modeling approach in a delegated authorization model. The data collection instruments utilized in this study also provides a systematic approach to evidence gathering that can be modified to suit other Open Banking related implementations.

## **6.3 Summary of Chapter 6**

This chapter concluded the study's findings and provided a consolidated answer to the research questions posed before. Additionally, it provided recommendations that organizations and policy makers can utilize to make Open Banking implementation more secure. It also suggested the ways in which the methodology and outcomes presented in this study can be further utilized and improved upon.

## References

- Akamai. (2025, June 10). *Open Finance, Open APIs and the rising stakes of security* | *Open Banking Expo*.  
Open Banking Expo. <https://www.openbankingexpo.com/usa/open-finance-open-apis-and-the-rising-stakes-of-security/>
- Bragin, M. (2024, June 29). *Evolve Bank & Trust Data Breach. What Happened?* Netbird.io.  
<https://netbird.io/knowledge-hub/evolve-bank-and-trust-data-breach>
- Dawood Behbehani, Muttukrishnan Rajarajan, Nikos Komninos, & Khalid Al-Begain. (2022). Detecting Open Banking API Security Threats Using Bayesian Attack Graphs. *2022 14th International Conference on Computational Intelligence and Communication Networks (CICN)*.  
<https://doi.org/10.1109/cicn56167.2022.10008365>
- Huy, S., Ang, S., Ho, M., & Balasubramaniam, V. (2026). Securing API Ecosystems in Banking: A Critical Review of Cyber Risks, Control Frameworks, and Future Trends. *Jordanian Journal of Informatics and Computing*, 2026(1), 25–37. <https://doi.org/10.63180/jjic.thestap.2026.1.3>
- Khorasani, V. (2024). Bank Transaction Dataset for Fraud Detection (Version 1) [Data set]. Kaggle.  
<https://www.kaggle.com/datasets/valakhorasani/bank-transaction-dataset-for-fraud-detection>
- Ojehomon, O. G., Cichorska, J., & Michnik, J. (2026). Cyber Risk Management of API-Enabled Financial Crime in Open Banking Services. *Entropy*, 28(2), 163. <https://doi.org/10.3390/e28020163>
- Open Banking is Creating New Fraud Challenges for the Banking Industry* | *Fraud.com*. (2022, June 12).  
Fraud.com. <https://www.fraud.com/post/open-banking-is-creating-new-fraud-challenges-for-the-banking-industry>
- OWASP. (2023). *OWASP Top 10 API Security Risks – 2023*. Owasp.org. <https://owasp.org/API-Security/editions/2023/en/0x11-t10/>
- Reynolds, J. A., Washington, M. T., Montgomery, E. K., Ortiz, S. L., & Yusuff, M. (2024, September 18). *Secure API Architectures for Open Banking*.  
[https://www.researchgate.net/publication/400508418\\_Secure\\_API\\_Architectures\\_for\\_Open\\_Banking](https://www.researchgate.net/publication/400508418_Secure_API_Architectures_for_Open_Banking)

- Shashi Kumar Munugoti. (2025). Secure API Gateway Strategies for Financial Institutions Using OAuth2 and Identity Federation. *Computer Fraud and Security*, 2097–2104. <https://doi.org/10.52710/cfs.865>
- Ünsal, E., Öztekin, B., Çavuş, M., & Özdemir, S. (2020, October 1). *Building a Fintech Ecosystem: Design and Development of a Fintech API Gateway*. IEEE Xplore. <https://doi.org/10.1109/ISNCC49221.2020.9297273>
- Wilson, C., & Tam, C. (2026). *Security Challenges in Open Banking: A Systematic Review and Conceptualisation of a Tri-Dimensional Security Framework*. <https://doi.org/10.20944/preprints202602.0867.v1>
- Zetsche, D. A., Arner, D. W., Buckley, R. P., & Weber, R. H. (2019). The Future of Data-Driven Finance and RegTech: Lessons from EU Big Bang II. *SSRN Electronic Journal*. <https://doi.org/10.2139/ssrn.3359399>

Appendices

Appendix A - Additional Tables & Figures

STRIDE Threat Map

Table 4 STRIDE Threat Map

|                        |                               |                   |           |         |
|------------------------|-------------------------------|-------------------|-----------|---------|
| <b>Spoofing</b>        | Attacker impersonates TPP     | OAuth token       | Exploited | Blocked |
| <b>Tampering</b>       | Forged token payload          | JWT claims        | Exploited | Blocked |
| <b>Repudiation</b>     | No record of access           | Audit log         | Exploited | Blocked |
| <b>Info Disclosure</b> | Customer data returned        | Account records   | Exploited | Blocked |
| <b>Elevation</b>       | Read scope to write operation | Transfer endpoint | Exploited | Blocked |

Token Flow

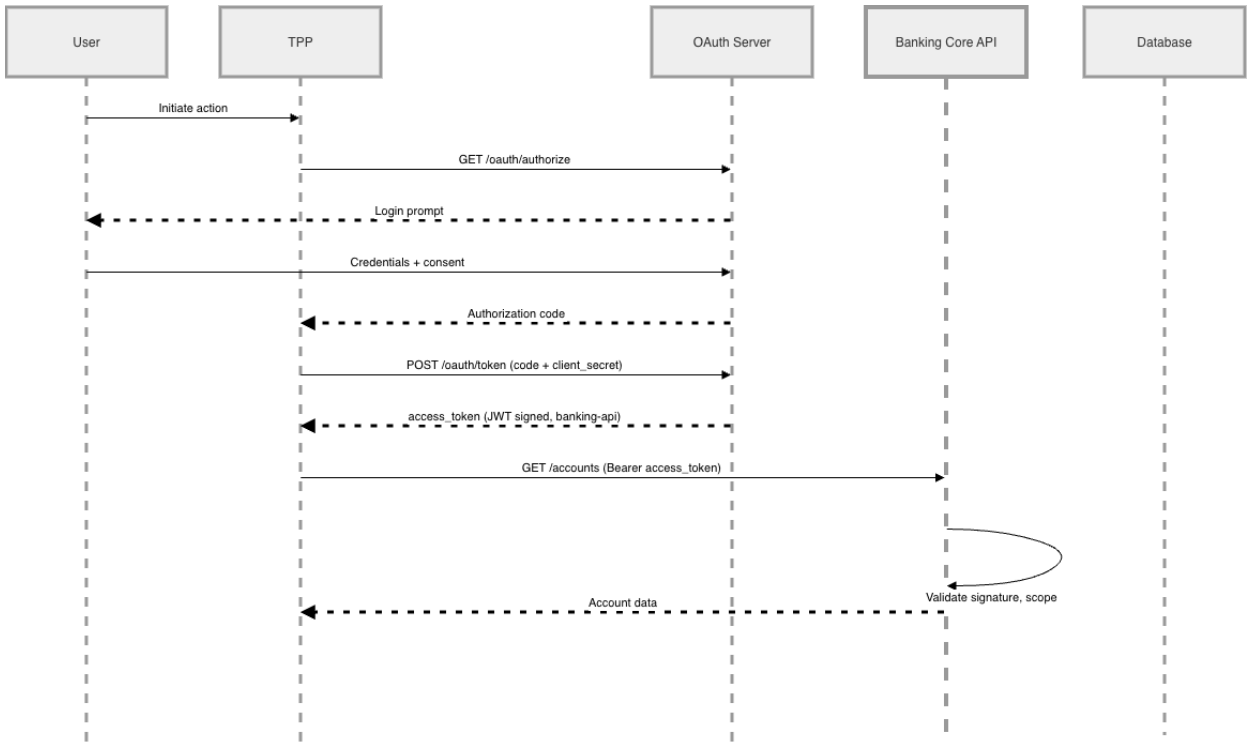
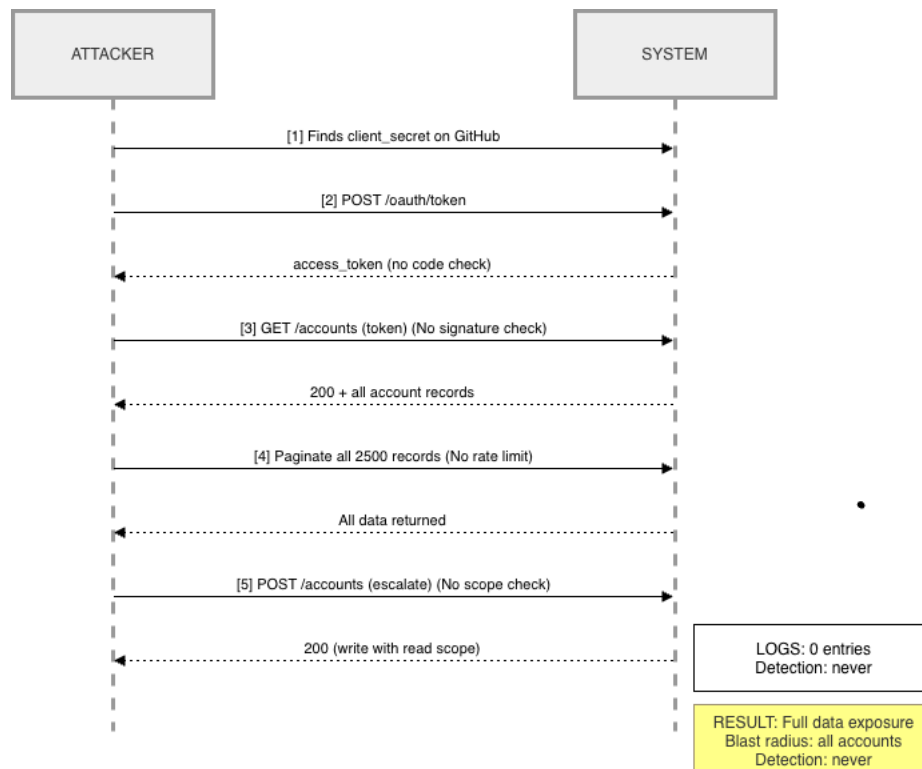


Figure 3 - Token Flow

Attack Chain



**Figure 4 Attack Chain from Iteration 1**